

HƯỚNG DẪN THỰC HIỆN BÀI TẬP LỚN

HỌC PHẦN FIT4012 - NHẬP MÔN AN TOÀN BẢO MẬT THÔNG TIN

CHỦ ĐỀ: SECURE SYSTEM UPGRADE CHALLENGE

NĂM HỌC 2025–2026

ThS. Lê Thị Thùy Trang, ThS. Nguyễn Văn Nhân

1 Mục tiêu của bài tập lớn

Bài tập lớn học phần **FIT4012 - Nhập môn An toàn bảo mật thông tin** được thiết kế theo định hướng **Secure System Upgrade Challenge**. Sinh viên không chỉ cài đặt thuật toán mã hóa riêng lẻ, mà cần vận dụng kiến thức đã học để thiết kế, triển khai, kiểm thử và đánh giá một hệ thống phần mềm có yếu tố bảo mật.

Bài tập lớn hướng tới các mục tiêu sau:

- Vận dụng các nguyên lý cơ bản của an toàn bảo mật thông tin, bao gồm tính bí mật, tính toàn vẹn, tính xác thực, tính sẵn sàng và khả năng truy vết.
- Phân tích được tài sản cần bảo vệ, tác nhân tham gia hệ thống, nguy cơ bảo mật và kịch bản tấn công có thể xảy ra.
- Lựa chọn và sử dụng phù hợp các thuật toán, giao thức, cơ chế xác thực, kiểm tra toàn vẹn và quản lý khóa.
- Cài đặt được một hệ thống có khả năng mã hóa, giải mã, xác thực, ghi log, xử lý lỗi và kiểm thử bảo mật.
- Trình bày được minh chứng kỹ thuật thông qua mã nguồn, báo cáo, sơ đồ thiết kế, test report, benchmark và video demo.

2 Tinh thần của bài tập lớn năm nay

Bài tập lớn năm nay được triển khai theo hướng **nâng cấp hệ thống bảo mật**.

Sinh viên có thể tham khảo ý tưởng, giao diện hoặc cấu trúc bài làm của các khóa trước. Sinh viên truy cập bài làm của khóa trước theo [Link này](#).

Tuy nhiên, mọi phần kế thừa phải được khai báo rõ trong báo cáo. Nhóm không được nộm lại nguyên mẫu cũ hoặc chỉ thay đổi hình thức như đổi tên file, đổi màu giao diện, đổi tên biến, đổi ảnh minh họa hoặc thay đổi rất nhỏ trong mã nguồn.

Mỗi nhóm bắt buộc phải bổ sung phần nâng cấp kỹ thuật mới so với bài làm của khóa trước. Phần nâng cấp phải được thể hiện bằng:

- Mã nguồn có thay đổi thực chất.
- Test case chứng minh hệ thống xử lý được tình huống đúng và tình huống sai.
- Báo cáo kiểm thử bảo mật.
- Sơ đồ luồng xử lý hoặc giao thức.
- Video demo.
- Lịch sử commit trên GitHub sau thời điểm nhận đề.

3 Yêu cầu chung

Sinh viên làm việc theo nhóm từ **2 đến 3 thành viên**.

Đề tài bài tập lớn do giảng viên chỉ định hoặc cho phép sinh viên lựa chọn trong danh sách đề tài ở phần 12.

Mỗi đề tài gồm hai phần:

1. **Phần nền:** mô tả bài toán gốc và các chức năng cơ bản cần xây dựng.
2. **Phần nâng cấp:** các yêu cầu bảo mật bắt buộc để phân biệt với bài làm của khóa trước.

Sản phẩm cuối cùng phải là một hệ thống chạy được, có mã nguồn rõ ràng, có báo cáo, có kiểm thử bảo mật và có minh chứng demo.

4 Yêu cầu kỹ thuật bắt buộc cho tất cả đề tài

4.1 Mã hóa dữ liệu

Tùy theo bài toán, hệ thống cần sử dụng cơ chế mã hóa phù hợp để bảo vệ dữ liệu trong quá trình truyền tải hoặc lưu trữ.

Khuyến nghị sử dụng:

- AES-GCM hoặc ChaCha20-Poly1305 cho mã hóa dữ liệu có xác thực.
- RSA-OAEP hoặc ECDH/X25519 kết hợp HKDF cho trao đổi hoặc dẫn xuất khóa.
- RSA-PSS, ECDSA hoặc Ed25519 cho chữ ký số.
- HMAC-SHA256 hoặc cơ chế tag xác thực để kiểm tra tính toàn vẹn và xác thực thông điệp.

Lưu ý:

- DES và TripleDES chỉ nên sử dụng như chế độ minh họa thuật toán cũ hoặc chế độ so sánh legacy.
- Không sử dụng DES hoặc TripleDES làm cấu hình bảo mật chính của hệ thống.
- Không tự cài đặt thuật toán mật mã từ đầu cho sản phẩm chính nếu không có yêu cầu riêng của đề tài.
- Nên sử dụng thư viện mật mã đáng tin cậy.

4.2 Xác thực và kiểm tra toàn vẹn

Hệ thống cần có cơ chế xác thực người gửi, người nhận, người dùng hoặc thiết bị tùy theo từng đề tài.

Hệ thống phải phát hiện được ít nhất một trong các trường hợp sau:

- Dữ liệu bị sửa đổi.
- Chữ ký không hợp lệ.
- Người gửi hoặc thiết bị không hợp lệ.
- Người dùng không có quyền truy cập.
- File hoặc gói tin bị thay đổi sau khi gửi.

4.3 Quản lý khóa hoặc phiên làm việc

Hệ thống cần mô tả rõ cách tạo khóa, trao đổi khóa, lưu khóa hoặc dẫn xuất khóa.

Các yêu cầu tối thiểu:

- Không hard-code khóa bí mật trực tiếp trong mã nguồn chính.
- Không in khóa bí mật, mật khẩu hoặc token ra log.

- Với bài toán truyền dữ liệu hoặc chat, cần có `session_id` hoặc cơ chế nhận diện phiên.
- Với bài toán lưu trữ mật khẩu, không lưu mật khẩu dạng rõ và không hash mật khẩu bằng SHA-256 đơn thuần.

4.4 Chống replay

Với các đề tài truyền dữ liệu, chat, IoT, upload/download hoặc gửi tài liệu qua server, hệ thống phải có cơ chế chống gửi lại dữ liệu cũ.

Có thể sử dụng một hoặc kết hợp các thành phần sau:

- `nonce`
- `timestamp`
- `sequence_number`
- `message_id`
- `session_id`
- danh sách gói tin đã xử lý

Hệ thống phải có test case chứng minh phát hiện được dữ liệu bị gửi lại.

4.5 Ghi log và xử lý lỗi

Hệ thống cần ghi lại các sự kiện quan trọng, ví dụ:

- Đăng nhập hoặc xác thực.
- Tạo phiên làm việc.
- Gửi và nhận dữ liệu.
- Mã hóa và giải mã.
- Xác minh chữ ký.
- Lỗi toàn vẹn dữ liệu.
- Lỗi quyền truy cập.
- Dữ liệu hết hạn.
- Replay hoặc dữ liệu bị gửi lại.

Log không được chứa mật khẩu thô, khóa bí mật hoặc dữ liệu nhạy cảm chưa mã hóa.

4.6 Kiểm thử bảo mật

Mỗi nhóm bắt buộc xây dựng test case cho cả trường hợp đúng và trường hợp sai.

Tối thiểu cần có:

- Test chạy đúng với dữ liệu hợp lệ.
- Test dữ liệu bị sửa đổi.
- Test sai khóa hoặc sai mật khẩu.
- Test sai chữ ký hoặc sai HMAC.
- Test replay hoặc gửi lại dữ liệu cũ.
- Test quyền truy cập không hợp lệ hoặc dữ liệu hết hạn nếu đề tài có yêu cầu phân quyền/thời hạn.

5 Nội dung báo cáo

Báo cáo bài tập lớn cần được trình bày rõ ràng, có hình ảnh minh họa, có bảng kết quả kiểm thử và có liên kết tới mã nguồn.

Báo cáo bắt buộc gồm các phần sau:

1. **Giới thiệu bài toán**
 - Bối cảnh thực tế.
 - Mục tiêu của hệ thống.
 - Lý do cần bảo mật.
2. **Mục tiêu bảo mật**
 - Tính bí mật.
 - Tính toàn vẹn.
 - Tính xác thực.
 - Tính sẵn sàng nếu có.
 - Khả năng truy vết nếu có.
3. **Threat model**
 - Tài sản cần bảo vệ.
 - Người dùng hợp lệ.
 - Tác nhân tấn công giả định.
 - Các nguy cơ bảo mật.
 - Các giả định và giới hạn của hệ thống.
4. **Kiến trúc hệ thống**
 - Thành phần client/server/cloud/database/game module nếu có.
 - Sơ đồ kiến trúc tổng quan.
 - Mô tả vai trò từng thành phần.
5. **Thiết kế giao thức hoặc luồng xử lý**
 - Sơ đồ sequence diagram hoặc flowchart.
 - Mô tả các bước: khởi tạo, xác thực, trao đổi khóa, mã hóa, truyền dữ liệu, xác minh, giải mã và ghi log.
6. **Thuật toán và thư viện sử dụng**
 - Thuật toán mã hóa.
 - Thuật toán hash/HMAC/chữ ký số.
 - Cơ chế quản lý khóa.
 - Thư viện lập trình sử dụng.
 - Lý do lựa chọn.
7. **Mô tả chức năng đã cài đặt**
 - Chức năng nền.
 - Chức năng nâng cấp.
 - Giao diện hoặc CLI nếu có.
8. **Phân tích mã nguồn**
 - Cấu trúc thư mục.
 - Các file chính.
 - Các hàm hoặc module quan trọng.
 - Cách chạy chương trình.
9. **Kiểm thử chức năng**
 - Các test case chạy đúng.
 - Kết quả đầu ra.
 - Ảnh minh họa hoặc log.
10. **Kiểm thử bảo mật**
 - Test dữ liệu bị sửa.
 - Test sai khóa.
 - Test sai chữ ký hoặc sai HMAC.
 - Test replay.
 - Test hết hạn hoặc sai quyền nếu có.
 - Nhận xét kết quả.
11. **Benchmark hiệu năng**
 - Thời gian mã hóa.
 - Thời gian giải mã.
 - Kích thước file hoặc số lượng bản ghi.
 - So sánh trước/sau nâng cấp nếu có.

12. Bảng kế thừa và nâng cấp

- Khai báo rõ phần tham khảo từ bài khóa trước.
- Phân tích phần nhóm tự nâng cấp.

13. Kết luận và hướng phát triển

- Những gì đã hoàn thành.
- Hạn chế.
- Hướng cải tiến.

6 Bảng kế thừa và nâng cấp bắt buộc

Mỗi nhóm bắt buộc đưa bảng sau vào báo cáo.

Thành phần	Bài khóa trước có gì?	Nhóm kế thừa gì?	Nhóm nâng cấp gì?	Minh chứng
Giao diện				Ảnh/video
Thuật toán				Code
Giao thức				Sequence diagram
Xác thực				Test case
Kiểm tra toàn vẹn				Test report
Chống replay				Log/test
Quản lý khóa				Mô tả/code
Logging				File log
Benchmark				Bảng kết quả
GitHub				Link repo

7 Sản phẩm cần nộp

Mỗi nhóm nộp các sản phẩm sau:

1. Link GitHub repository.
2. File báo cáo PDF.
3. Video demo từ 5 đến 7 phút.
4. File README.md hướng dẫn cài đặt và chạy chương trình.
5. Test report mô tả các trường hợp kiểm thử.
6. Benchmark report nếu có yêu cầu trong đề tài.
7. Bảng phân công công việc.
8. Bảng kế thừa và nâng cấp.
9. Slide thuyết trình nếu giảng viên yêu cầu.

8 Cấu trúc GitHub repository gợi ý

Mỗi nhóm nên tổ chức mã nguồn theo cấu trúc sau:

```
fit4012-secure-system/
  README.md
  report/
    report.pdf
    figures/
  docs/
```

```

threat_model.md
protocol_design.md
test_report.md
benchmark.md
src/
  client/
  server/
  crypto/
  utils/
tests/
  test_valid_flow.py
  test_tampering.py
  test_replay.py
  test_invalid_key.py
sample_data/
requirements.txt

```

Cấu trúc trên có thể thay đổi tùy ngôn ngữ lập trình và loại đề tài.

9 Ngôn ngữ lập trình và công cụ

Sinh viên có thể sử dụng một trong các ngôn ngữ lập trình sau:

- Python
- Java
- C#
- JavaScript/TypeScript
- C++
- Ngôn ngữ khác nếu được giảng viên đồng ý

Khuyến nghị thư viện:

- Python: cryptography, pycryptodome, bcrypt, argon2-cffi, pytest, Flask, FastAPI
- Java: javax.crypto, Bouncy Castle, JUnit
- C#: System.Security.Cryptography, ASP.NET Core
- JavaScript/TypeScript: Web Crypto API, Node.js crypto, Jest
- C++: OpenSSL, libsodium

Lưu ý quan trọng:

- Không lưu mật khẩu dạng rõ.
- Không hash mật khẩu bằng SHA-256 đơn thuần.
- Không dùng cùng nonce/IV cho nhiều lần mã hóa.
- Không hard-code khóa bí mật trong mã nguồn chính.
- Không đưa file dữ liệu nhạy cảm thật lên GitHub.
- Không đưa private key thật lên GitHub.
- Không in khóa bí mật hoặc mật khẩu ra màn hình/log.

10 Rubric chấm điểm

Tiêu chí	Tỷ trọng
Phân tích bài toán, threat model, misuse case	10%

Tiêu chí	Tỷ trọng
Thiết kế kiến trúc, giao thức, sơ đồ xử lý	15%
Cài đặt chức năng nền	20%
Cài đặt phần nâng cấp bảo mật	20%
Kiểm thử bảo mật và benchmark	15%
Báo cáo, GitHub, README, video demo	10%
Thuyết trình và trả lời câu hỏi	10%

11 Quy định về điểm trừ

Nhóm có thể bị trừ điểm trong các trường hợp sau:

- Không có GitHub repository hoặc repository không chạy được.
- Không có README hướng dẫn chạy.
- Không có test case bảo mật.
- Không có bảng kế thừa và nâng cấp.
- Chỉ đổi giao diện hoặc đổi tên biến từ bài cũ.
- Sử dụng lại mã nguồn của khóa trước nhưng không khai báo.
- Hard-code khóa bí mật hoặc mật khẩu trong mã nguồn chính.
- Lưu mật khẩu dạng rõ.
- Báo cáo không giải thích được thuật toán hoặc giao thức đã sử dụng.
- Thành viên không nắm được phần việc của mình khi thuyết trình.

12 Đề tài bài tập lớn

12.1 Nhóm đề tài truyền file an toàn

Đề tài 1: Secure Expiring Document – Gửi tài liệu email có giới hạn thời gian

12.1.0.1 Bối cảnh Một người gửi cần gửi tài liệu quan trọng cho người nhận qua môi trường mạng. Tài liệu chỉ được phép mở trong một khoảng thời gian nhất định. Sau khi hết hạn, hệ thống phải từ chối giải mã hoặc từ chối truy cập.

12.1.0.2 Chức năng nền

- Người gửi chọn file tài liệu.
- Hệ thống mã hóa file trước khi gửi.
- Người nhận xác thực và giải mã file.
- Hệ thống kiểm tra tính toàn vẹn của file sau khi nhận.

12.1.0.3 Yêu cầu nâng cấp bắt buộc

- Sử dụng cơ chế mã hóa có xác thực, khuyến nghị AES-GCM hoặc ChaCha20-Poly1305.
- Mỗi file phải có metadata gồm: `file_id`, `sender_id`, `receiver_id`, `timestamp`, `expire_time`, `nonce`.
- Hệ thống phải phát hiện file bị sửa đổi.
- Hệ thống phải từ chối mở file sau thời gian hết hạn.
- Hệ thống phải phát hiện trường hợp gói tin cũ bị gửi lại.
- Có log cho các sự kiện gửi, nhận, giải mã thành công, giải mã thất bại và hết hạn.

12.1.0.4 Kiểm thử bắt buộc

- Gửi và mở file trong thời gian hợp lệ.
- Mở file sau thời gian hết hạn.
- Sửa một byte trong ciphertext và kiểm tra hệ thống có từ chối không.
- Gửi lại gói tin cũ và kiểm tra hệ thống có phát hiện replay không.
- Dùng sai khóa hoặc sai người nhận để giải mã.

12.1.0.5 Sản phẩm cần nộp

- Mã nguồn chương trình.
- README hướng dẫn chạy.
- Báo cáo PDF.
- Video demo.
- Test report.
- Bảng kế thừa và nâng cấp so với bài khóa trước.

Đề tài 2: Zero-Knowledge Relay Server – Gửi báo cáo công ty qua server trung gian

12.1.0.6 Bối cảnh Một công ty cần gửi báo cáo nội bộ thông qua một server trung gian. Server được phép chuyển tiếp dữ liệu và ghi nhận giao dịch, nhưng không được đọc nội dung báo cáo.

12.1.0.7 Chức năng nền

- Client gửi báo cáo tới server trung gian.
- Server trung gian chuyển tiếp báo cáo tới người nhận.
- Người nhận giải mã và kiểm tra toàn vẹn báo cáo.
- Server ghi lại thời gian gửi và trạng thái chuyển tiếp.

12.1.0.8 Yêu cầu nâng cấp bắt buộc

- Server trung gian không được lưu hoặc đọc báo cáo ở dạng rõ.
- Báo cáo phải được mã hóa đầu cuối giữa người gửi và người nhận.
- Mỗi giao dịch có `transaction_id`, `session_id`, `timestamp` và `nonce`.
- Server phải ghi audit log cho từng lần chuyển tiếp.
- Người nhận phải phát hiện được báo cáo bị sửa đổi.
- Có cơ chế phát hiện gói tin bị gửi lại.

12.1.0.9 Kiểm thử bắt buộc

- Gửi báo cáo hợp lệ qua server.
- Kiểm tra server không có bản rõ của báo cáo.
- Sửa báo cáo tại server và kiểm tra người nhận từ chối.
- Gửi lại giao dịch cũ và kiểm tra hệ thống phát hiện replay.
- Kiểm tra log chuyển tiếp của server.

12.1.0.10 Sản phẩm cần nộp

- Source code client/server.
- Báo cáo mô tả kiến trúc.
- Sequence diagram quá trình gửi báo cáo.
- File log mẫu.
- Video demo.

Đề tài 3: Multi-Part Digital Contract Signing – Gửi hợp đồng với chữ ký số riêng

12.1.0.11 Bối cảnh Một hợp đồng điện tử gồm nhiều phần. Mỗi phần hợp đồng cần được ký và xác minh riêng, đồng thời toàn bộ hợp đồng cũng cần có chữ ký tổng để đảm bảo không bị sửa, thiếu hoặc đảo thứ tự.

12.1.0.12 Chức năng nền

- Người gửi chia hợp đồng thành nhiều phần.
- Mỗi phần có hash và chữ ký số.
- Người nhận xác minh chữ ký.
- Hệ thống ghép lại hợp đồng sau khi xác minh.

12.1.0.13 Yêu cầu nâng cấp bắt buộc

- Sử dụng chữ ký số RSA-PSS, ECDSA hoặc Ed25519.
- Mỗi phần hợp đồng có `part_id`, `contract_id`, `sequence_number`, `hash`, `signature`.
- Toàn bộ hợp đồng có manifest được ký số.
- Hệ thống phát hiện thiếu phần, thừa phần, đảo thứ tự hoặc sửa nội dung.
- Có log cho quá trình xác minh từng phần.

12.1.0.14 Kiểm thử bắt buộc

- Xác minh hợp đồng hợp lệ.
- Sửa một phần hợp đồng.
- Xóa một phần hợp đồng.
- Đảo thứ tự các phần.
- Dùng sai public key để xác minh.

12.1.0.15 Sản phẩm cần nộp

- Source code.
- Hợp đồng mẫu.
- Manifest mẫu.
- Test report.
- Video demo.

Đề tài 4: Secure Compressed Financial Report – Gửi báo cáo tài chính có nén dữ liệu

12.1.0.16 Bối cảnh Báo cáo tài chính thường có kích thước lớn và cần được bảo vệ khi truyền qua mạng. Hệ thống cần nén dữ liệu trước khi mã hóa để giảm kích thước truyền tải, đồng thời vẫn đảm bảo tính bảo mật và toàn vẹn.

12.1.0.17 Chức năng nền

- Người gửi chọn file báo cáo.
- Hệ thống nén file.
- Hệ thống mã hóa file đã nén.
- Người nhận giải mã và giải nén.
- Hệ thống kiểm tra dữ liệu sau giải nén.

12.1.0.18 Yêu cầu nâng cấp bắt buộc

- Thực hiện theo quy trình: nén dữ liệu, mã hóa, truyền tải, giải mã, giải nén, kiểm tra toàn vẹn.
- Sử dụng mã hóa có xác thực.
- Lưu metadata gồm kích thước gốc, kích thước sau nén, thuật toán nén, thời gian nén, thời gian mã hóa.
- Có benchmark tỉ lệ nén và thời gian xử lý với ít nhất 3 file có kích thước khác nhau.
- Phát hiện ciphertext bị sửa hoặc file nén bị lỗi.

12.1.0.19 Kiểm thử bắt buộc

- Gửi báo cáo hợp lệ.
- Sửa ciphertext.
- Sửa file nén sau khi giải mã.
- So sánh hash của file gốc và file sau giải nén.
- Benchmark ít nhất 3 kích thước file.

12.1.0.20 Sản phẩm cần nộp

- Source code.
- Báo cáo benchmark.
- Test report.
- Video demo.

Đề tài 5: Secure Medical Record Transfer with MFA – Gửi bệnh án với xác thực kép

12.1.0.21 Bối cảnh Bệnh án là dữ liệu nhạy cảm, chỉ người có thẩm quyền mới được truy cập. Hệ thống cần bảo vệ bệnh án khi truyền tải và yêu cầu xác thực kép trước khi giải mã.

12.1.0.22 Chức năng nền

- Người gửi mã hóa bệnh án.
- Người nhận đăng nhập.
- Người nhận thực hiện bước xác thực thứ hai.
- Hệ thống giải mã bệnh án nếu xác thực hợp lệ.

12.1.0.23 Yêu cầu nâng cấp bắt buộc

- Mật khẩu người dùng phải được lưu bằng bcrypt, Argon2id hoặc PBKDF2 kèm salt.
- Không lưu mật khẩu thô hoặc hash SHA-256 đơn thuần.
- Bổ sung xác thực kép bằng OTP giả lập, email code giả lập hoặc mã token tạm thời.
- Bệnh án được mã hóa bằng cơ chế có xác thực.
- Có vai trò tối thiểu: bác sĩ, nhân viên lưu trữ, auditor.
- Ghi log mọi lần truy cập bệnh án.

12.1.0.24 Kiểm thử bắt buộc

- Đăng nhập đúng và xác thực kép đúng.
- Sai mật khẩu.
- Sai OTP/token.
- Người dùng không có quyền truy cập.
- Sửa ciphertext bệnh án.
- Kiểm tra log truy cập.

12.1.0.25 Sản phẩm cần nộp

- Source code.
- Tài khoản mẫu.
- Báo cáo phân quyền.
- Test report.
- Video demo.

Đề tài 6: Secure Assignment Chunk Transfer – Gửi bài tập chia thành nhiều phần

12.1.0.26 Bối cảnh Một file bài tập lớn được chia thành nhiều phần để truyền qua mạng. Hệ thống cần đảm bảo các phần được nhận đầy đủ, đúng thứ tự và không bị sửa đổi.

12.1.0.27 Chức năng nền

- Chia file bài tập thành nhiều chunk.
- Gửi từng chunk qua mạng.
- Người nhận ghép lại file.
- Kiểm tra file sau khi ghép.

12.1.0.28 Yêu cầu nâng cấp bắt buộc

- Mỗi chunk có `file_id`, `chunk_id`, `sequence_number`, `total_chunks`, `nonce`, `tag`.
- Mỗi chunk được mã hóa hoặc xác thực riêng.
- Có manifest mô tả toàn bộ file.
- Hệ thống phát hiện thiếu chunk, trùng chunk, đảo thứ tự chunk hoặc chunk bị sửa.
- Có cơ chế resume hoặc gửi lại chunk bị thiếu.

12.1.0.29 Kiểm thử bắt buộc

- Gửi file hợp lệ.
- Làm mất một chunk.
- Gửi trùng một chunk.
- Đảo thứ tự chunk.
- Sửa nội dung một chunk.
- Kiểm tra hash file sau khi ghép.

12.1.0.30 Sản phẩm cần nộp

- Source code.
- File mẫu.
- Manifest mẫu.
- Test report.
- Video demo.

Đề tài 7: Secure Audio Segment Transfer – Gửi tập tin âm thanh chia thành nhiều đoạn

12.1.0.31 Bối cảnh Một file âm thanh lớn cần được chia thành nhiều đoạn để truyền tải. Hệ thống cần đảm bảo các đoạn âm thanh được bảo vệ, nhận đúng thứ tự và có thể phát lại chính xác.

12.1.0.32 Chức năng nền

- Chia file âm thanh thành nhiều đoạn.
- Mã hóa và gửi từng đoạn.
- Người nhận giải mã và ghép các đoạn.
- Kiểm tra file âm thanh sau khi ghép.

12.1.0.33 Yêu cầu nâng cấp bắt buộc

- Mỗi đoạn âm thanh có metadata: `audio_id`, `segment_id`, `sequence_number`, `duration`, `format`, `nonce`.
- Có manifest chứa hash của từng đoạn và hash toàn bộ file.
- Hệ thống phát hiện thiếu đoạn, sửa đoạn hoặc đảo thứ tự.
- Có benchmark với ít nhất hai định dạng âm thanh, ví dụ `.wav` và `.mp3`.
- Có log quá trình gửi và ghép đoạn.

12.1.0.34 Kiểm thử bắt buộc

- Gửi file âm thanh hợp lệ.
- Làm mất một đoạn.
- Sửa một đoạn.
- Đảo thứ tự đoạn.
- Ghép sai định dạng.
- So sánh hash file âm thanh gốc và file sau khi ghép.

12.1.0.35 Sản phẩm cần nộp

- Source code.
- File âm thanh mẫu.
- Manifest mẫu.
- Benchmark report.
- Video demo.

Đề tài 8: Secure Recruitment Submission – Gửi CV an toàn có kiểm tra IP

12.1.0.36 Bối cảnh Ứng viên gửi CV cho nhà tuyển dụng qua hệ thống trực tuyến. Hệ thống cần xác thực người gửi, bảo vệ CV và hạn chế truy cập trái phép.

12.1.0.37 Chức năng nền

- Ứng viên tải lên CV.
- Hệ thống kiểm tra thông tin người gửi.
- CV được mã hóa trước khi lưu hoặc gửi.
- Nhà tuyển dụng được phép tải xuống và giải mã CV.

12.1.0.38 Yêu cầu nâng cấp bắt buộc

- Không chỉ dựa vào IP để xác thực.
- Bổ sung token phiên hoặc mã xác thực tạm thời.
- CV có metadata gồm `candidate_id`, `job_id`, `upload_time`, `expire_time`, `nonce`.
- Hệ thống phát hiện CV bị sửa đổi.
- Có log truy cập của nhà tuyển dụng.
- Có cơ chế từ chối tải CV sau thời gian hết hạn nếu đề tài thiết kế theo hướng link hết hạn.

12.1.0.39 Kiểm thử bắt buộc

- Ứng viên hợp lệ gửi CV.
- Truy cập từ IP hoặc token không hợp lệ.
- Sửa file CV.
- Tải CV sau thời gian hết hạn.
- Nhà tuyển dụng không có quyền tải CV.

12.1.0.40 Sản phẩm cần nộp

- Source code.
- README.
- Báo cáo quyền truy cập.
- Test report.
- Video demo.

Đề tài 9: Secure Watermarked Image Sharing – Gửi ảnh có gắn watermark

12.1.0.41 Bối cảnh Một người gửi cần gửi ảnh có bản quyền cho người nhận. Ảnh cần được gắn watermark để nhận diện chủ sở hữu và được mã hóa khi truyền tải.

12.1.0.42 Chức năng nền

- Người gửi chọn ảnh.
- Hệ thống gắn watermark.
- Hệ thống mã hóa ảnh.
- Người nhận giải mã và kiểm tra watermark.

12.1.0.43 Yêu cầu nâng cấp bắt buộc

- Có visible watermark hoặc invisible watermark đơn giản.
- Metadata gồm image_id, owner_id, receiver_id, watermark_hash, timestamp, nonce.
- Ảnh được mã hóa bằng cơ chế có xác thực.
- Hệ thống phát hiện ảnh bị sửa sau khi giải mã.
- Có so sánh ảnh trước và sau khi gắn watermark.
- Có log quá trình tạo và xác minh watermark.

12.1.0.44 Kiểm thử bắt buộc

- Gửi ảnh hợp lệ.
- Sửa ciphertext.
- Crop hoặc sửa ảnh sau giải mã.
- Xóa watermark nếu có thể và kiểm tra hệ thống phản ứng.
- Dùng sai người nhận để giải mã.

12.1.0.45 Sản phẩm cần nộp

- Source code.
- Ảnh mẫu.
- Báo cáo so sánh ảnh.
- Test report.
- Video demo.

Đề tài 10: Authenticated IoT Cloud Ingestion – Giả lập upload/download dữ liệu IoT lên cloud với log thời gian

12.1.0.46 Bối cảnh Nhiều thiết bị IoT gửi dữ liệu cảm biến lên cloud. Hệ thống cần xác thực thiết bị, bảo vệ dữ liệu và ghi log thời gian gửi.

12.1.0.47 Chức năng nền

- Giả lập nhiều thiết bị IoT.
- Thiết bị gửi dữ liệu lên cloud.
- Cloud lưu dữ liệu và log thời gian.
- Người dùng tải dữ liệu về.

12.1.0.48 Yêu cầu nâng cấp bắt buộc

- Mỗi thiết bị có `device_id` và khóa riêng.
- Dữ liệu cảm biến có timestamp và chữ ký/HMAC.
- Cloud kiểm tra thiết bị có hợp lệ không.
- Cloud phát hiện replay dữ liệu cũ.
- Cloud phát hiện dữ liệu bị sửa.
- Có dashboard hoặc log thể hiện dữ liệu theo từng thiết bị.

12.1.0.49 Kiểm thử bắt buộc

- Thiết bị hợp lệ gửi dữ liệu.
- Thiết bị giả mạo gửi dữ liệu.
- Sửa giá trị cảm biến.
- Gửi lại gói tin cũ.
- Timestamp bất thường.
- Kiểm tra log theo thiết bị.

12.1.0.50 Sản phẩm cần nộp

- Source code.
- Dữ liệu IoT mẫu.
- Log cloud.
- Test report.
- Video demo.

Đề tài 11: Resumable Secure Video Upload – Giả lập upload/download video lên cloud với xử lý lỗi mạng

12.1.0.51 Bối cảnh Video có kích thước lớn và dễ gặp lỗi khi upload. Hệ thống cần hỗ trợ upload an toàn, xử lý lỗi mạng và tiếp tục upload từ điểm bị gián đoạn.

12.1.0.52 Chức năng nền

- Người dùng chọn video.
- Hệ thống chia video thành chunk.
- Upload từng chunk lên cloud giả lập.
- Download và ghép lại video.

12.1.0.53 Yêu cầu nâng cấp bắt buộc

- Mỗi chunk có video_id, chunk_id, sequence_number, nonce, tag.
- Có cơ chế retry khi timeout.
- Có cơ chế resume upload khi bị gián đoạn.
- Cloud phát hiện chunk bị sửa hoặc bị gửi trùng.
- Có benchmark với ít nhất 3 kích thước video.
- Có log lỗi mạng và số lần retry.

12.1.0.54 Kiểm thử bắt buộc

- Upload video hợp lệ.
- Mô phỏng mất mạng giữa chừng.
- Resume upload.
- Sửa một chunk.
- Gửi trùng chunk.
- Benchmark thời gian upload/download.

12.1.0.55 Sản phẩm cần nộp

- Source code.
- Video mẫu.
- Log retry.
- Benchmark report.
- Video demo.

Đề tài 12: DRM-like Secure Music Delivery – Gửi tập tin nhạc có bản quyền

12.1.0.56 Bối cảnh Một nền tảng âm nhạc cần gửi file nhạc cho người dùng có quyền nghe. File nhạc cần được mã hóa, kèm thông tin bản quyền và có thể có thời hạn nghe thử.

12.1.0.57 Chức năng nền

- Người gửi chọn file nhạc.
- Hệ thống mã hóa file nhạc.
- Người nhận có quyền giải mã và nghe.
- Hệ thống kiểm tra thông tin bản quyền.

12.1.0.58 Yêu cầu nâng cấp bắt buộc

- File nhạc có metadata bản quyền được ký số.
- Có license token hoặc quyền nghe thử.
- File nhạc được mã hóa bằng cơ chế có xác thực.
- Hệ thống phát hiện metadata bản quyền bị sửa.
- Hệ thống từ chối giải mã nếu license hết hạn hoặc không hợp lệ.
- Có log cấp quyền và sử dụng quyền.

12.1.0.59 Kiểm thử bắt buộc

- Người dùng hợp lệ mở file nhạc.
- License hết hạn.
- Sửa metadata bản quyền.
- Sửa ciphertext.

- Người dùng không có quyền mở file.

12.1.0.60 Sản phẩm cần nộp

- Source code.
- File nhạc mẫu.
- License token mẫu.
- Test report.
- Video demo.

Đề tài 13: Multi-Hop Legal Document Transfer – Gửi tài liệu pháp lý qua nhiều server trung gian

12.1.0.61 Bối cảnh Tài liệu pháp lý được gửi qua nhiều server trung gian trước khi tới người nhận. Hệ thống cần đảm bảo tài liệu không bị sửa và có thể truy vết đường đi.

12.1.0.62 Chức năng nền

- Người gửi gửi tài liệu qua nhiều server.
- Mỗi server chuyển tiếp tài liệu.
- Người nhận nhận và giải mã tài liệu.
- Hệ thống ghi log quá trình chuyển tiếp.

12.1.0.63 Yêu cầu nâng cấp bắt buộc

- Tài liệu được mã hóa đầu cuối.
- Mỗi server trung gian ký log chuyển tiếp.
- Mỗi bước chuyển tiếp có `hop_id`, `server_id`, `timestamp`, `previous_hash`.
- Audit trail có cấu trúc dạng chuỗi hash đơn giản.
- Người nhận kiểm tra được đường đi của tài liệu.
- Hệ thống phát hiện log bị sửa hoặc server bỏ qua bước chuyển tiếp.

12.1.0.64 Kiểm thử bắt buộc

- Chuyển tài liệu qua đầy đủ server.
- Sửa tài liệu tại một server.
- Xóa một dòng log.
- Sửa timestamp.
- Bỏ qua một server trung gian.
- Kiểm tra audit trail.

12.1.0.65 Sản phẩm cần nộp

- Source code.
- Sơ đồ multi-hop.
- Audit log mẫu.
- Test report.
- Video demo.

Đề tài 14: Tamper-Evident Audio Cloud Storage – Giả lập upload/download nội dung âm thanh lên cloud với phát hiện sửa đổi

12.1.0.66 Bối cảnh Một hệ thống cloud lưu trữ nội dung âm thanh. Hệ thống cần phát hiện mọi thay đổi trái phép trên nội dung âm thanh sau khi upload.

12.1.0.67 Chức năng nền

- Người dùng upload file âm thanh.
- Cloud lưu file.
- Người dùng download file.
- Hệ thống kiểm tra file sau download.

12.1.0.68 Yêu cầu nâng cấp bắt buộc

- File âm thanh được mã hóa bằng AES-GCM hoặc ChaCha20-Poly1305.
- Có manifest chứa hash file, kích thước, định dạng, timestamp và nonce.
- Cloud lưu manifest riêng với file mã hóa.
- Hệ thống phát hiện thay đổi ở ciphertext, nonce, tag hoặc manifest.
- Có log upload/download và xác minh toàn vẹn.

12.1.0.69 Kiểm thử bắt buộc

- Upload/download hợp lệ.
- Sửa ciphertext.
- Sửa nonce.
- Sửa tag.
- Sửa manifest.
- So sánh hash file gốc và file tải về.

12.1.0.70 Sản phẩm cần nộp

- Source code.
- File âm thanh mẫu.
- Manifest mẫu.
- Test report.
- Video demo.

Đề tài 15: Multi-Cloud Secure Replication – Giả lập upload/download tài liệu lên nhiều cloud

12.1.0.71 Bối cảnh Tài liệu quan trọng được lưu trên nhiều cloud để tăng tính sẵn sàng. Hệ thống cần đảm bảo các bản sao không bị sửa đổi và có thể tải từ cloud dự phòng khi một cloud lỗi.

12.1.0.72 Chức năng nền

- Người dùng upload tài liệu.
- Hệ thống lưu tài liệu lên nhiều cloud giả lập.
- Người dùng download tài liệu từ một cloud.
- Hệ thống kiểm tra toàn vẹn tài liệu.

12.1.0.73 Yêu cầu nâng cấp bắt buộc

- Tài liệu được mã hóa trước khi upload lên các cloud.
- Mỗi cloud lưu bản sao mã hóa và metadata riêng.
- Hệ thống so sánh hash/tag giữa các cloud.
- Phát hiện cloud bị sửa dữ liệu hoặc mất dữ liệu.
- Có cơ chế tải từ cloud dự phòng.
- Có log trạng thái từng cloud.

12.1.0.74 Kiểm thử bắt buộc

- Upload tài liệu lên nhiều cloud.
- Một cloud bị sửa dữ liệu.
- Một cloud mất file.
- Download từ cloud dự phòng.
- So sánh toàn vẹn giữa các cloud.
- Kiểm tra log trạng thái.

12.1.0.75 Sản phẩm cần nộp

- Source code.
- Cloud giả lập.
- Log đồng bộ.
- Test report.
- Video demo.

12.2 Nhóm đề tài xây dựng ứng dụng chat an toàn

Đề tài 16: End-to-End Secure Text Chat v2 – Ứng dụng bảo mật tin nhắn văn bản với mã hóa AES và xác thực RSA

12.2.0.1 Bối cảnh Hai người dùng cần trao đổi tin nhắn văn bản qua môi trường mạng. Hệ thống cần bảo vệ nội dung tin nhắn, xác thực người gửi và phát hiện tin nhắn bị sửa hoặc gửi lại.

12.2.0.2 Chức năng nền

- Người dùng đăng nhập hoặc định danh.
- Hai người dùng tạo phiên chat.
- Tin nhắn được mã hóa trước khi gửi.
- Người nhận giải mã và hiển thị tin nhắn.

12.2.0.3 Yêu cầu nâng cấp bắt buộc

- Sử dụng AES-GCM hoặc ChaCha20-Poly1305 cho tin nhắn.
- Sử dụng RSA-OAEP/ECDH để trao đổi hoặc dẫn xuất khóa phiên.
- Mỗi tin nhắn có `message_id`, `session_id`, `sequence_number`, `timestamp`, `nonce`.
- Có xác thực người gửi bằng chữ ký số hoặc HMAC.
- Có chống replay tin nhắn.
- Khuyến khích cập nhật khóa phiên sau một số lượng tin nhắn.

12.2.0.4 Kiểm thử bắt buộc

- Gửi tin nhắn hợp lệ.
- Sửa ciphertext.
- Sửa sequence number.
- Gửi lại tin nhắn cũ.
- Dùng sai khóa phiên.
- Giả mạo người gửi.

12.2.0.5 Sản phẩm cần nộp

- Source code.
- Demo chat.
- Sequence diagram.
- Test report.
- Video demo.

Đề tài 17: Secure Voice Message Chat – Ứng dụng bảo mật tin nhắn âm thanh với mã hóa AES và xác thực RSA

12.2.0.6 Bối cảnh Người dùng gửi tin nhắn âm thanh trong ứng dụng chat. Hệ thống cần mã hóa nội dung âm thanh, xác thực người gửi và phát hiện tin nhắn âm thanh bị sửa.

12.2.0.7 Chức năng nền

- Ghi âm hoặc chọn file âm thanh.
- Mã hóa tin nhắn âm thanh.
- Gửi tin nhắn tới người nhận.
- Người nhận giải mã và phát lại.

12.2.0.8 Yêu cầu nâng cấp bắt buộc

- Mỗi voice message có `voice_id`, `sender_id`, `receiver_id`, `duration`, `format`, `timestamp`, `nonce`.
- File âm thanh được mã hóa bằng AES-GCM hoặc ChaCha20-Poly1305.
- Metadata quan trọng được ký hoặc xác thực bằng HMAC.
- Phát hiện audio bị sửa, metadata bị sửa hoặc tin nhắn bị replay.
- Có giới hạn kích thước file âm thanh.
- Có log gửi/nhận voice message.

12.2.0.9 Kiểm thử bắt buộc

- Gửi voice message hợp lệ.
- Sửa file âm thanh.
- Sửa metadata.
- Gửi lại voice message cũ.
- Dùng sai người nhận để giải mã.
- Gửi file vượt kích thước cho phép.

12.2.0.10 Sản phẩm cần nộp

- Source code.
- File âm thanh mẫu.
- Test report.
- Video demo.

Đề tài 18: Legacy DES Attack and Migration Chat – Ứng dụng bảo mật tin nhắn văn bản với mã hóa DES và xác thực RSA

12.2.0.11 Bối cảnh Một hệ thống chat cũ sử dụng DES để mã hóa tin nhắn. Nhóm cần xây dựng phiên bản mô phỏng hệ thống cũ, phân tích hạn chế và nâng cấp sang cơ chế mã hóa hiện đại.

12.2.0.12 Chức năng nền

- Cài đặt chế độ chat văn bản legacy dùng DES.
- Tin nhắn được mã hóa và giải mã.
- Có xác thực cơ bản bằng RSA hoặc chữ ký số.
- Hiển thị kết quả chat.

12.2.0.13 Yêu cầu nâng cấp bắt buộc

- DES chỉ được dùng như chế độ legacy để minh họa, không phải cấu hình bảo mật chính.
- Bổ sung chế độ mới dùng AES-GCM hoặc ChaCha20-Poly1305.
- So sánh DES và cơ chế mới về kích thước khóa, mode hoạt động, tính an toàn và hiệu năng.
- Hệ thống cảnh báo khi người dùng chọn DES.
- Có test minh họa rủi ro nếu dùng cấu hình legacy không đúng.

12.2.0.14 Kiểm thử bắt buộc

- Gửi tin nhắn bằng chế độ DES legacy.
- Gửi tin nhắn bằng chế độ hiện đại.
- Sửa ciphertext.
- So sánh thời gian mã hóa/giải mã.
- Kiểm tra cảnh báo khi dùng DES.
- Viết nhận xét vì sao DES không nên dùng trong hệ thống thực tế.

12.2.0.15 Sản phẩm cần nộp

- Source code.
- Báo cáo so sánh DES và AES-GCM/ChaCha20-Poly1305.
- Benchmark report.
- Video demo.

Đề tài 19: Legacy Voice Encryption Migration – Ứng dụng bảo mật tin nhắn âm thanh với mã hóa DES và xác thực RSA

12.2.0.16 Bối cảnh Một ứng dụng chat âm thanh cũ sử dụng DES để mã hóa file âm thanh. Nhóm cần mô phỏng chế độ cũ và nâng cấp sang cơ chế bảo vệ hiện đại.

12.2.0.17 Chức năng nền

- Gửi tin nhắn âm thanh.
- Mã hóa file âm thanh bằng DES trong chế độ legacy.
- Xác thực người gửi.
- Người nhận giải mã và phát lại.

12.2.0.18 Yêu cầu nâng cấp bắt buộc

- DES chỉ dùng cho chế độ legacy.
- Bổ sung chế độ hiện đại dùng AES-GCM hoặc ChaCha20-Poly1305.
- Có bảng so sánh DES và thuật toán mới.
- Hệ thống phát hiện audio bị sửa trong chế độ hiện đại.
- Có benchmark với ít nhất 2 file âm thanh kích thước khác nhau.
- Có cảnh báo khi người dùng chọn legacy mode.

12.2.0.19 Kiểm thử bắt buộc

- Gửi audio bằng DES legacy.
- Gửi audio bằng chế độ hiện đại.
- Sửa ciphertext.
- Sửa metadata.
- So sánh thời gian xử lý.
- Kiểm tra cảnh báo legacy mode.

12.2.0.20 Sản phẩm cần nộp

- Source code.
- File audio mẫu.
- Báo cáo migration.
- Test report.
- Video demo.

Đề tài 20: Secure Chat with Legacy Compatibility – Ứng dụng bảo mật tin nhắn văn bản với mã hóa TripleDES và xác thực RSA

12.2.0.21 Bối cảnh Một hệ thống chat cần hỗ trợ tương thích với TripleDES nhưng đồng thời phải khuyến nghị người dùng sử dụng cấu hình mã hóa hiện đại.

12.2.0.22 Chức năng nền

- Gửi và nhận tin nhắn văn bản.
- Có chế độ TripleDES legacy.
- Có xác thực người gửi.
- Có giao diện hoặc CLI chat.

12.2.0.23 Yêu cầu nâng cấp bắt buộc

- TripleDES chỉ dùng cho chế độ tương thích.
- Chế độ chính phải dùng AES-GCM hoặc ChaCha20-Poly1305.
- Người dùng chọn thuật toán thì hệ thống hiển thị cảnh báo nếu chọn legacy mode.
- Tin nhắn có `message_id`, `timestamp`, `nonce`, `session_id`.
- Có chống replay tin nhắn.
- Có báo cáo so sánh legacy mode và modern mode.

12.2.0.24 Kiểm thử bắt buộc

- Gửi tin nhắn bằng TripleDES legacy.
- Gửi tin nhắn bằng modern mode.
- Replay tin nhắn.

- Sửa ciphertext.
- Dùng sai khóa.
- Kiểm tra cảnh báo legacy.

12.2.0.25 Sản phẩm cần nộp

- Source code.
- Báo cáo so sánh.
- Test report.
- Benchmark report.
- Video demo.

12.3 Nhóm đề tài bảo mật cơ sở dữ liệu

Đề tài 21: Modern Password Authentication System – Ứng dụng SHA và TripleDES để bảo vệ mật khẩu người dùng trong cơ sở dữ liệu

12.3.0.1 Bối cảnh Một hệ thống đăng nhập cần bảo vệ mật khẩu người dùng trong cơ sở dữ liệu. Nhóm cần phân tích vì sao SHA hoặc TripleDES không phù hợp để lưu mật khẩu theo cách thông thường và xây dựng phiên bản bảo vệ hiện đại hơn.

12.3.0.2 Chức năng nền

- Người dùng đăng ký tài khoản.
- Người dùng đăng nhập.
- Hệ thống lưu thông tin tài khoản trong cơ sở dữ liệu.
- Hệ thống kiểm tra mật khẩu khi đăng nhập.

12.3.0.3 Yêu cầu nâng cấp bắt buộc

- Không lưu mật khẩu dạng rõ.
- Không hash mật khẩu bằng SHA-256 đơn thuần.
- Không mã hóa mật khẩu bằng TripleDES để lưu trữ như cấu hình chính.
- Sử dụng bcrypt, Argon2id hoặc PBKDF2 kèm salt.
- Có cơ chế khóa tài khoản hoặc delay sau nhiều lần đăng nhập sai.
- Có log đăng nhập thành công/thất bại.
- Có chức năng đổi mật khẩu an toàn.

12.3.0.4 Kiểm thử bắt buộc

- Đăng ký tài khoản mới.
- Đăng nhập đúng.
- Đăng nhập sai nhiều lần.
- Kiểm tra mật khẩu trong database không ở dạng rõ.
- Kiểm tra mỗi người dùng có salt khác nhau nếu dùng cơ chế có salt.
- Đổi mật khẩu và đăng nhập lại.

12.3.0.5 Sản phẩm cần nộp

- Source code.
- Database mẫu.
- Test report.

- Ảnh hoặc log minh họa mật khẩu đã được bảo vệ.
- Video demo.

Đề tài 22: Secure Personal Data Vault – Ứng dụng TripleDES và AES để bảo vệ thông tin nhạy cảm trong cơ sở dữ liệu

12.3.0.6 Bối cảnh Một hệ thống lưu trữ thông tin nhạy cảm như số điện thoại, email, số giấy tờ hoặc thông tin cá nhân. Hệ thống cần mã hóa dữ liệu nhạy cảm và kiểm soát quyền truy cập.

12.3.0.7 Chức năng nền

- Người dùng nhập dữ liệu cá nhân.
- Hệ thống lưu dữ liệu vào cơ sở dữ liệu.
- Người dùng có quyền có thể xem lại dữ liệu.
- Dữ liệu nhạy cảm được mã hóa.

12.3.0.8 Yêu cầu nâng cấp bắt buộc

- AES-GCM là cơ chế mã hóa chính cho dữ liệu nhạy cảm.
- TripleDES chỉ dùng để so sánh hoặc chế độ legacy.
- Có phân quyền tối thiểu: user, admin, auditor.
- Admin không được mặc định xem dữ liệu nhạy cảm nếu không có quyền giải mã.
- Mọi lần giải mã dữ liệu nhạy cảm phải ghi audit log.
- Có cơ chế quản lý khóa hoặc mô tả cách bảo vệ khóa.
- Có test dữ liệu trong database không ở dạng rõ.

12.3.0.9 Kiểm thử bắt buộc

- User tạo dữ liệu nhạy cảm.
- User xem dữ liệu của mình.
- Admin không có quyền giải mã dữ liệu nếu chưa được cấp quyền.
- Auditor xem log nhưng không xem dữ liệu nhạy cảm.
- Sửa ciphertext trong database.
- Kiểm tra log giải mã.

12.3.0.10 Sản phẩm cần nộp

- Source code.
- Database mẫu.
- Audit log mẫu.
- Test report.
- Video demo.

12.4 Nhóm đề tài phát triển game mang tính giáo dục và mô phỏng bảo mật

Đề tài 23: CyberBank Security Game v2 – Game “Hệ thống mã hóa ngân hàng”

12.4.0.1 Bối cảnh Sinh viên xây dựng một game giáo dục mô phỏng hệ thống ngân hàng. Người chơi cần bảo vệ giao dịch trước các nguy cơ như sửa số tiền, giả mạo chữ ký, replay giao dịch hoặc dùng khóa sai.

12.4.0.2 Chức năng nền

- Người chơi thực hiện giao dịch ngân hàng giả lập.
- Hệ thống mã hóa hoặc ký giao dịch.
- Người chơi quan sát kết quả giao dịch.
- Game có nhiều màn chơi hoặc nhiệm vụ.

12.4.0.3 Yêu cầu nâng cấp bắt buộc

- Game phải có ít nhất 4 tình huống bảo mật:
 - giao dịch hợp lệ;
 - sửa số tiền;
 - replay giao dịch cũ;
 - giả mạo chữ ký hoặc khóa sai.
- Người chơi phải chọn hoặc triển khai biện pháp phòng thủ phù hợp.
- Mỗi màn chơi có phần giải thích vì sao tấn công thành công hoặc thất bại.
- Có cơ chế tính điểm.
- Có log lịch sử giao dịch trong game.
- Có hướng dẫn học thuật ngắn cho từng khái niệm bảo mật.

12.4.0.4 Kiểm thử bắt buộc

- Giao dịch hợp lệ.
- Sửa số tiền.
- Gửi lại giao dịch cũ.
- Dùng sai chữ ký.
- Dùng sai khóa.
- Kiểm tra tính điểm và giải thích sau mỗi màn.

12.4.0.5 Sản phẩm cần nộp

- Source code game.
- Hướng dẫn chơi.
- Báo cáo mô tả kiến trúc bảo mật trong game.
- Video demo gameplay.
- Test report.

Đề tài 24: Crypto Quest v2 – Game “Giải mã kho báu”

12.4.0.6 Bối cảnh Sinh viên xây dựng một game giáo dục về mật mã học. Người chơi vượt qua các màn chơi bằng cách giải mã, phát hiện lỗi thiết kế mật mã và lựa chọn cơ chế bảo vệ phù hợp.

12.4.0.7 Chức năng nền

- Game có cốt truyện tìm kho báu.
- Người chơi giải các câu đố mật mã.
- Có các thuật toán cổ điển hoặc hiện đại ở mức mô phỏng.
- Có điểm số hoặc cấp độ.

12.4.0.8 Yêu cầu nâng cấp bắt buộc

- Game phải có ít nhất 5 màn chơi.
- Các màn chơi nên đi từ dễ đến khó, ví dụ:
 - Caesar hoặc Vigenere;
 - hash và kiểm tra toàn vẹn;
 - mã hóa đối xứng;
 - khóa công khai;
 - lỗi thiết kế như dùng lại nonce, hash không salt hoặc replay message.
- Mỗi màn chơi phải có giải thích kiến thức sau khi hoàn thành.
- Có ít nhất 2 màn yêu cầu người chơi phát hiện lỗi bảo mật, không chỉ giải mã.
- Có cơ chế lưu điểm hoặc lưu tiến độ.
- Có phần hướng dẫn cho giảng viên/sinh viên sử dụng game trong học tập.

12.4.0.9 Kiểm thử bắt buộc

- Hoàn thành từng màn chơi.
- Nhập đáp án sai.
- Kiểm tra tính điểm.
- Kiểm tra lưu tiến độ.
- Kiểm tra phần giải thích kiến thức.
- Kiểm tra màn phát hiện lỗi bảo mật.

12.4.0.10 Sản phẩm cần nộp

- Source code game.
- Hướng dẫn chơi.
- Báo cáo mô tả kiến thức mật mã.
- Video demo gameplay.
- Test report.

13 Checklist trước khi nộp bài

Trước khi nộp bài, nhóm cần tự kiểm tra:

- ☐ Repository GitHub có README rõ ràng.
- ☐ Có hướng dẫn cài đặt và chạy chương trình.
- ☐ Có dữ liệu mẫu để chạy thử.
- ☐ Có báo cáo PDF.
- ☐ Có video demo.
- ☐ Có test report.
- ☐ Có benchmark nếu đề tài yêu cầu.
- ☐ Có threat model.
- ☐ Có sơ đồ kiến trúc hoặc sequence diagram.
- ☐ Có bảng kế thừa và nâng cấp.
- ☐ Không có mật khẩu, private key hoặc dữ liệu nhạy cảm thật trong repository.
- ☐ Các thành viên đều hiểu phần việc của mình.

14 Kết luận

Bài tập lớn FIT4012 năm nay không chỉ yêu cầu sinh viên xây dựng một chương trình có sử dụng thuật toán mật mã, mà yêu cầu sinh viên chứng minh được tư duy thiết kế hệ thống an toàn. Sản phẩm cần thể hiện rõ khả năng phân tích rủi ro, lựa chọn cơ chế bảo vệ phù hợp, cài đặt chức năng, kiểm thử tình huống tấn công và trình bày minh chứng kỹ thuật.

Tinh thần chung của bài tập lớn là:

Không làm lại bài cũ, mà nâng cấp bài cũ thành một hệ thống an toàn hơn, có kiểm thử và có minh chứng rõ ràng.